NEXUS SECURITY ADVISORS

SOC 2 Readiness Roadmap & Self-Check

SaaS companies and service providers facing customer security reviews

Step-by-step path to a SOC 2 report under the AICPA Trust Services Criteria. SOC 1 reports on controls relevant to customers' financial reporting (SSAE 18, AT-C 320); SOC 2 reports on security, availability, processing integrity, confidentiality, and privacy (AT-C 205); SOC 3 is a public summary of a SOC 2. A Type I report tests control design at a point in time; a Type II tests operating effectiveness over an observation period, commonly 3 to 12 months. Only a licensed CPA firm can issue the report.

Organization: _____ Completed by: _____ Date: _____

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	SOC2-01	Step 1: Plan	Decide which report you need (SOC 1, SOC 2, or SOC 3) based on what customers are asking for	AICPA SOC suite	High	Customer requirements list
☐	SOC2-02	Step 1: Plan	Define scope: services, systems, people, data, and locations in the system description	SOC 2 description criteria (DC 200)	High	Draft system description
☐	SOC2-03	Step 1: Plan	Select Trust Services Criteria categories (Security is required; add Availability, Confidentiality, Processing Integrity, Privacy as needed)	AICPA TSC	High	Category decision memo
☐	SOC2-04	Step 1: Plan	Choose Type I (design, point in time) or Type II (operating effectiveness over a period)	AICPA SOC 2	High	Report type decision; target dates
☐	SOC2-05	Step 2: Assess	Run a readiness / gap assessment against the criteria	AICPA TSC	High	Gap assessment report
☐	SOC2-06	Step 3: Build Controls	Control environment: board/management oversight, code of conduct, background checks	CC1	Medium	Org chart; policies; HR records
☐	SOC2-07	Step 3: Build Controls	Communication and information: security policies published and acknowledged	CC2	Medium	Policy acknowledgements
☐	SOC2-08	Step 3: Build Controls	Risk assessment: annual risk assessment including fraud and vendor risk	CC3	High	Risk register
☐	SOC2-09	Step 3: Build Controls	Monitoring activities: ongoing control monitoring and internal review	CC4	Medium	Control monitoring evidence
☐	SOC2-10	Step 3: Build Controls	Control activities: documented controls mapped to risks	CC5	Medium	Control matrix
☐	SOC2-11	Step 3: Build Controls	Logical and physical access: MFA, least privilege, access reviews, encryption	CC6	High	Access review records; MFA evidence

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	SOC2-12	Step 3: Build Controls	System operations: logging, monitoring, vulnerability management, incident response	CC7	High	SIEM alerts; scan reports; IR plan
☐	SOC2-13	Step 3: Build Controls	Change management: reviewed, tested, and approved changes	CC8	High	Change tickets; code review records
☐	SOC2-14	Step 3: Build Controls	Risk mitigation: vendor management and business continuity	CC9	Medium	Vendor reviews; BCP/DR test
☐	SOC2-15	Step 4: Evidence	Automate evidence collection and assign a control owner for each control	Best practice	Medium	Evidence repository or compliance platform
☐	SOC2-16	Step 5: Audit	Engage a licensed CPA firm and agree on the audit period and timeline	AICPA	High	Engagement letter
☐	SOC2-17	Step 5: Audit	Complete the Type I or Type II examination and remediate any exceptions	AICPA SOC 2	High	Final SOC 2 report
☐	SOC2-18	Step 6: Maintain	Renew annually; issue bridge letters to customers between report periods	Best practice	Medium	Renewal plan; bridge letter template

Readiness self-check for general guidance only. Not legal advice and not a formal assessment or certification. Confirm requirements against official sources.